

Enumeracion de SNMP

Objetivos de aprendizaje

Identificar la superficie, explicar la causa, diseñar una confirmación mínima, interpretar evidencia y proponer una mitigación causal.

Prerrequisitos

Flujo source-transformación-validación-sink, parsers, permisos y metodología de hipótesis. Revisa los prerrequisitos declarados en los metadatos.

Fundamentos técnicos

SNMP (puerto 161/UDP) es un protocolo de gestion y monitorizacion de dispositivos de red. Se autentica con una 'community string' en vez de usuario/password; si el dispositivo sigue usando la que trae por defecto ('public' para lectura), cualquiera que la conozca puede consultar una cantidad enorme de informacion del sistema: procesos en ejecucion (con sus argumentos, que a veces llevan credenciales), interfaces de red, software instalado, y en Windows a veces hasta usuarios locales.

La community string por defecto es publica y conocida (esta en cualquier manual); si el administrador no la cambia, SNMP queda abierto a cualquiera que sepa probarla. No es un fallo del protocolo, es no cambiar una credencial por defecto, igual que smb-enum con sesiones nulas.

Modelo mental

Entrada controlada -> transformaciones -> validación -> componente final
-> sink -> efecto observable -> decisión

El paso crítico es demostrar qué componente consume el valor y con qué identidad o privilegios.

Superficie de ataque

Cuando el recon muestra 161/UDP abierto (nmap -sU lo detecta, un escaneo TCP normal NO lo vera). Muy rentable en maquinas de red/infraestructura.

Cómo identificarla

- Puerto 161/UDP abierto (solo visible con un escaneo UDP, no en el TCP por defecto).
- snmpwalk con 'public' devuelve datos en vez de timeout.
- Los datos incluyen procesos con linea de comandos completa, a veces con credenciales en los argumentos.

Preguntas que debo hacerme

- ¿Qué dato controlo exactamente y en qué formato viaja?
- ¿Qué transformaciones y normalizaciones ocurren antes del sink?
- ¿Qué identidad ejecuta la operación y qué permisos tiene?
- ¿Qué otra explicación produciría la misma señal?
- ¿Cuál es la prueba de menor riesgo que separa ambas explicaciones?

Prueba mínima

Consulta con snmpwalk usando la community 'public' (la mas comun por defecto).

Evidencia esperada: Una respuesta con datos del sistema (nombre de host, procesos, interfaces) confirma que la community funciona. Timeout repetido sugiere filtrado UDP o community incorrecta (difícil distinguir sin mas pruebas).

Construcción progresiva del payload

1. Reproduce una entrada válida.
2. Aísla un único valor controlable.
3. Define la primitiva mínima indicada por la fuente.
4. Predice resultado y control negativo.
5. Aplica una sola adaptación cuando haya evidencia de restricción.
6. Confirma de forma reproducible antes de ampliar impacto.

Capa 1: prueba documentada

```
snmpwalk -v2c -c public $IP
```

Objetivo y contexto: Vuelca toda la información accesible vía SNMPv2 con la community 'public', la que casi siempre viene por defecto si nadie la cambia.

Resultado esperado: Cientos de líneas con datos del sistema. Busca específicamente procesos (hrSWRunParameters) y su línea de comandos completa: ahí caen credenciales a menudo.

Anatomía de los payloads

La primera prueba es `snmpwalk -v2c -c public $IP`. Separa sus delimitadores, operadores, opciones, operandos y variables; algunos elementos no estarán presentes según el contexto. Las comillas, barras y separadores pertenecen a una capa concreta. Usa la explicación de cada capa para determinar qué símbolo altera sintaxis y cuál transporta datos.

Variaciones según el contexto

No traslades una prueba entre sistemas operativos, motores, frameworks o versiones sin revisar sintaxis y comportamiento. Conserva la primitiva y vuelve a serializarla para el parser real.

Filtros y bypasses

No existe un bypass universal. Registra la forma enviada, la forma decodificada, la comparación, la normalización y la forma consumida. Una adaptación es válida solo si demuestra una discrepancia concreta; si la validación ocurre sobre la forma canónica y expresa la propiedad correcta, la variante no debe funcionar.

Evidencias de confirmación

Una respuesta con datos del sistema (nombre de host, procesos, interfaces) confirma que la community funciona. Timeout repetido sugiere filtrado UDP o community incorrecta (difícil distinguir sin más pruebas).

Usa además una entrada inocua y un control negativo. No confundas reflexión, error genérico o demora aislada con confirmación.

Escalado de impacto

- Confirma el puerto con un escaneo UDP (`nmap -sU`); un TCP normal no lo detecta.
- Prueba la community 'public' primero (la más común); si falla, prueba otras por defecto (`private`, `community`) o fuerza bruta si el reto lo sugiere.
- Vuelca toda la información disponible (procesos, software, interfaces) con `snmpwalk`.
- Revisa la línea de comandos de cada proceso: es un sitio clásico donde aparecen credenciales pasadas como argumento.

Amplía únicamente dentro del laboratorio y cuando cada salto aporte una capacidad nueva demostrable.

Errores frecuentes

- La community string 'public' es rechazada y no tienes otra candidata que probar.

- El puerto aparece 'open|filtered' de forma persistente sin responder a ninguna consulta (UDP filtrado, no un SNMP mal configurado).
- Ejecutar la prueba sin adaptar variables ni versión.
- Cambiar varias capas a la vez.
- Omitir el control negativo o no guardar evidencia.

Diagnóstico de payloads fallidos

Síntoma	Posible causa	Prueba de diagnóstico	Adaptación
Rechazo inmediato	Formato o precondition	Repetir entrada válida	Corregir transporte
Sin diferencia	Entrada ignorada o canal ciego	Marcador y control negativo	Buscar evidencia adecuada
Error del componente	Contexto o versión	Reducir a prueba mínima	Consultar manual detectado
Resultado parcial	Permisos/restricción	Comprobar identidad y alcance	Reducir primitiva

Mitigaciones

Eliminar el dato controlable del sink cuando sea posible; usar APIs estructuradas, allowlists sobre valores canónicos, privilegio mínimo, autorización en servidor y registros que permitan detectar abuso. La defensa concreta debe impedir la causa explicada en Fundamentos técnicos.

Relación con pentesting y certificaciones

Se espera reconocer la señal, justificar la prueba elegida, adaptar variables, interpretar salida y documentar impacto y mitigación. La puntuación debe premiar razonamiento y evidencia, no memoria literal.

Caso guiado

Parte de una señal de la lista anterior. Escribe observación e hipótesis, ejecuta la prueba mínima, compara con el control y clasifica el resultado como no confirmado, indicio o confirmación. Solo entonces sigue los pasos de escalado relevantes.

Caso de adaptación

Si la prueba básica falla, no cambies caracteres al azar. Comprueba primero transporte, parser, versión, permisos y canal de evidencia. Diseña una segunda prueba que discrimine entre las dos causas más probables.

Ejercicios

1. Señala source, transformaciones y sink en el caso guiado.
2. Explica qué evidencia refutaría la hipótesis.
3. Descompón la primera prueba documentada por opciones y argumentos.
4. Propón un control negativo y una mitigación causal.

Resumen

SNMP con la community string 'public' filtra procesos, usuarios y software instalado sin necesitar credenciales reales. La técnica queda confirmada solo cuando una prueba mínima produce la evidencia prevista y descarta explicaciones alternativas.

Chuleta operativa

1. Confirmar alcance y preconditiones.

2. Identificar entrada, componente y permisos.
3. Ejecutar prueba mínima y control.
4. Interpretar señal antes de escalar.
5. Guardar evidencia y mitigación.

Referencias

- Concepto fuente de THM Fieldbook (snmp-enum)
- Referencia técnica externa

Navegación

Anterior: Construcción de payloads. Índice: curso. Ejercicios y chuleta se enlazarán desde la matriz de trazabilidad.